A.2 Security+ Final Assessment

Date: 1/2/2026, 11:51:53 PM

Time Spent: 39:22

Score: 89%

Passing Score: 80%

Question 1 Correct

Open-source intelligence is gathering information from unconventional and freely available sources. Vulnerabilities found via this information are ones to prioritize for remediation as they have often not progressed to the point where they can endanger an organization. Where can this information come from? (Select the three best options.)

- [ ] Word of mouth
- [x] Dark web ✓ Correct
- [x] Social media ✓ Correct
- [x] Blogs/forums ✓ Correct

Explanation

The dark web is sites, content, and services accessible only over a dark net. While dark web search engines exist, many hidden sites do not appear.

Social media platforms allow hackers who recently discovered a vulnerability to showcase what they have done and allow others to exploit it before deploying a patch.

Blogs/forums provide another location for malicious actors to showcase their accomplishments, share hacking tools and are a vital source for open-source intelligence (OSINT).

Open-source intelligence (OSINT) via "word of mouth" would not provide the same level of information as the other choices would. Word-of-mouth information would travel much too slowly to impact an organization's security.

Related Content

resources\questions\sy0-701_4_3_002b.question.xml

Question 2 Correct

The IT Manager at a multinational corporation wants to enhance the corporation's overall cybersecurity posture by implementing compensating technical controls. The organization has challenges implementing multi-factor authentication due to the nature of its operations. Which of the following should they consider?

- Installing a network intrusion detection system (NIDS)
- Implementing a rigorous password complexity and change schedule. ✓ Correct
- Conducting regular security risk assessments
- Implementing firewalls at key network junctures

Explanation

Implementing a rigorous password complexity and change schedule is an example of a compensating control. In situations where multi-factor authentication isn't feasible, a rigorous password policy can provide comparable security protection.

Although an NIDS is a technical control, it is not a compensating control. It is a preventive control that seeks to stop security incidents before they occur, not a control that comes into play when another control fails or is insufficient.

Regular security risk assessments help select controls but are not compensating, as they don't provide a secondary defense when a primary control fails.

Firewalls at key network junctures are technical controls, not compensating ones. They prevent unauthorized access as primary defenses, not secondary ones.

Related Content

resources\questions\q_pt_sy0-701_1_1_007.question.xml

Question 3 ✕ Incorrect

A cloud storage company wants to ensure that it stores user data in the same country as the user's physical location. Which factor is the cloud storage company primarily considering here?

- (●) Data sovereignty ✕ Incorrect
- ( ) Geolocation ✓ Correct
- ( ) Data integrity
- ( ) Data classification

Explanation

Geolocation refers to the identification of the geographic location of an object, such as a computing device or server.

Data sovereignty is relevant in this context. However, in this scenario, the primary factor the cloud storage company is considering is where it should store user data based on the user's location, which is a task for geolocation.

Data classification involves categorizing data based on its sensitivity level (i.e., public, confidential). This process can help organizations determine appropriate security measures, but it is not the primary factor the cloud storage company is considering.

Data integrity is maintaining and assuring the accuracy and consistency of data over its lifecycle. While a critical aspect of data management, it is not the primary consideration.

Related Content

resources\questions\sy0-701_3_3_007.question.xml

Question 4 Correct

A technician prepares a presentation to the board of directors on the variances between compliance reporting and monitoring after the board receives word that the company did poorly on its last assessment. What are the tenets of compliance reporting? (Select the two best options.)

- [ ] It uses automation to improve accuracy and streamlines observation activities.
- [x] It aims to access and disclose an organization's compliance status. ✓ Correct
- [x] It promotes accountability, transparency, and effective compliance management. ✓ Correct
- [ ] It conducts thorough investigations and assessments of third parties.

Explanation

Internal and external compliance reporting aims to assess and disclose an organization's compliance status but differ in scope, audience, and purpose.

Both internal and external compliance reporting forms promote accountability, transparency, and effective compliance management within organizations.

Compliance with legal and regulatory requirements, industry standards, and internal policies demonstrates confirmation through diligent monitoring of an organization's actions. Compliance monitoring involves conducting thorough investigations and assessments of third parties, such as vendors or business partners, to ensure they comply with relevant regulations.

Automation is vital in compliance monitoring as it streamlines monitoring activities, improves accuracy, and enhances the ability to detect noncompliance or anomalies promptly.

Related Content

resources\questions\q_pt_sy0-701_5_4_004.question.xml

Question 5 Correct

A medium-sized organization implements a secure access service edge (SASE) solution to secure its distributed network. The IT manager wants to protect all data in transit. Which of the following should the organization implement alongside SASE to achieve this goal?

- (selected) A Transport Layer Security (TLS) protocol to secure data in transit ✓ Correct
- A Software-Defined Wide Area Network (SD-WAN) to manage network connectivity
- A Layer 4 firewall to control access to network resources
- A standalone intrusion detection system (IDS) to monitor network traffic

Explanation

The Transport Layer Security (TLS) protocol encrypts data in transit, providing an additional layer of security alongside SASE to help to ensure sensitive information remains confidential and protected from unauthorized access.

While an intrusion detection system (IDS) can monitor network traffic for signs of security threats, it doesn't specifically secure data in transit, meaning data could still be vulnerable to interception or tampering.

An SD-WAN can manage network connectivity and optimize traffic routing but does not inherently secure data in transit, so additional measures may be necessary to protect sensitive information.

A Layer 4 firewall controls access to network resources by filtering traffic based on port numbers and protocols, but it does not specifically secure data in transit.

Related Content

resources\questions\sy0-701_3_2_015.question.xml

Question 6 Correct

A company wants to reduce the capital expenses associated with maintaining its own physical servers and switch to a model that offers scalability based on demand. What is the MOST suitable solution for the company's objectives?

- Virtualization
- On-premises infrastructure
- Centralization
- Cloud model ✓ Correct

Explanation

Cloud computing provides cost savings by reducing capital expenses associated with owning and maintaining physical servers and offers scalability based on demand.

Virtualization is a technology that allows multiple operating systems to run on a single physical server, optimizing resources and potentially reducing costs. However, it does not inherently offer the scalability or cost benefits on demand that cloud computing does.

On-premises solutions involve owning and managing physical servers in-house, which typically involves high capital expenses and does not provide scalability based on demand offered by the cloud.

While centralization models can have cost implications, they do not offer the direct cost savings and scalability benefits associated with cloud computing.

Related Content

resources\questions\sy0-701_3_1_010.question.xml

Question 7 Correct

A company is reviewing its policies to ensure compliance with data privacy regulations. It wants to establish a policy that outlines the appropriate use of customer data. What type of policy should the company focus on?

- Information security policy
- Acceptable use policy (AUP)
- Data privacy policy ✓ Correct
- Disaster recovery policy

Explanation

The company is specifically concerned about compliance with data privacy regulations. Therefore, it should develop a data privacy policy outlining customer data handling to maintain compliance with relevant laws and data privacy protection.

An AUP focuses on defining acceptable behavior by users regarding network and computer systems; it may not specifically address data privacy.

An information security policy is broader and covers guidelines related to information security within the organization, including data privacy. However, this scenario needs a more specific data privacy policy.

Unrelated to data privacy, a disaster recovery policy focuses on recovering from catastrophic events or disruptions.

Related Content

resources\questions\q_sy0-701_1_3_001a.question.xml

Question 8 Correct

A cybersecurity analyst at a large corporation notices suspicious activity from one of the employee accounts. Log entries indicate that the same account is accessing the company's intranet from two countries just an hour apart. However, the employee is currently on a business trip and is only using wireless connections. Which security anomaly is occurring in this situation?

- Distributed denial-of-service (DDoS)
- Brute force attack
- Wireless misconfiguration
- Impossible travel ✓ Correct

Explanation

Impossible travel is a security alert triggered when a user's account logs in from two distant locations in a short time span, which is a scenario not feasible with normal travel. In this case, the log entries suggest an impossible travel scenario.

The employee used wireless connections. However, this does not explain the suspicious activity detected in the log entries on the employee's account.

Distributed denial-of-service (DDoS) attacks flood the bandwidth or resources of a targeted system. The scenario concerns an unusual login pattern rather than a resource overload.

Brute force can lead to unauthorized access; however, it does not explain the simultaneous logins from distant locations observed in this scenario.

Related Content

resources\questions\sy0-701_2_4_002a.question.xml

Question 9 Correct

A targeted attack has a budget that can allocate physical and human resources to achieve its goals. This type of attack contains what attribute?

- Unskilled attacker
- Known threats
- Sophistication ✓ Correct
- Opportunistic

Explanation

One must consider an adversaries' sophistication and level of resources and funding. A targeted attack might use highly sophisticated tools backed by a budget that can allocate physical and human resources.

Opportunistic attacks might launch without much sophistication or funding, simply by using tools widely available on the Internet.

An unskilled attacker uses hacker tools without necessarily understanding how they work or having the ability to craft new attacks. Unskilled attacker attacks might have no specific target or any reasonable goal other than gaining attention.

Known threats, such as viruses or rootkits, Trojans, botnets, distributed denial-of-service (DDoS), or specific software vulnerabilities, are relatively straightforward to identify. Organizations can scan for these types of threats with automated software.

Related Content

resources\questions\q_sy0-701_2_1_016.question.xml

Question 10 Correct

A network administrator configures the security for data transmitted by employees working remotely. The data includes personal employee information such as addresses and phone numbers. Which category does this scenario BEST fit?

- Confidential
- Regulated
- Private ✓ Correct
- Public

Explanation

Private data is any information that is personal in nature and not meant for the general public to access. Private data includes personal employee information such as addresses or phone numbers.

Regulated refers to data subject to specific legal or regulatory controls, which the scenario does not specifically mention. Not all private data is necessarily regulated.

Public refers to data that is freely available to the general public. The data in this scenario is private employee information, which should not be publicly available.

Confidential data in a business context refers to proprietary company data. In this scenario, private data is a better fit as it refers specifically to personal information.

Related Content

resources\questions\q_pt_sy0-701_3_3_006.question.xml

Question 11 Correct

What component of the incident response process applies mitigation techniques and controls to remove unauthorized configuration changes from systems?

- (selected) Eradication ✓ Correct
- Detection
- Containment
- Analysis

Explanation

The eradication process applies mitigation techniques and controls to remove the intrusion tools and unauthorized configuration changes from systems.

Detection is the process of correlating events from network and system data sources and determining whether they are indicators of an incident. When a suspicious event triggers a concern, a notification must be sent to the appropriate person on the computer incident response team (CIRT), who can take charge of the situation and formulate the appropriate response.

Analysis occurs when the first responder analyzes the data to determine whether it identified a genuine incident and assigns the appropriate priority level.

Containment occurs after detection and analysis. It is the process of removing affected components from the larger environment.

Related Content

resources\questions\q_pt_sy0-701_4_8_002.question.xml

Question 12 ✕ Incorrect

After failing a regulatory exam on compliance, an organization looks for methods to systematically assess, evaluate, and report its adherence to laws, regulations, and industry standards. What is a true statement regarding compliance monitoring?

- Compliance monitoring facilitates stakeholder communication and decision-making.
- Compliance monitoring provides high-level summaries of an organization's compliance performance.
- Compliance monitoring involves risk assessments, data collection, and analysis. ✓ Correct
- Compliance monitoring focuses on operational details and supports internal decision-making. ✕ Incorrect

Explanation

Diligent monitoring of an organization's actions confirms compliance with legal and regulatory requirements, industry standards, and internal policies. Compliance monitoring involves risk assessments, data collection, and analysis.

Internal compliance reporting, and not compliance monitoring, focuses on operational details and supports internal decision-making.
External compliance reporting adheres to regulatory requirements and provides high-level summaries of an organization's compliance performance. It is both internal and external compliance reporting, and not monitoring, that facilitates stakeholder communication and decision-making. Both internal and external reporting forms promote accountability, transparency, and effective compliance management within organizations.

Related Content

resources\questions\sy0-701_5_4_007.question.xml

Question 13 Correct

Evaluating the security risks tied to a company's virtualized environment, a network administrator for the company relies on multiple virtual machines (VMs) for service distribution throughout the infrastructure. The administrator's primary concern is a specific risk: an application compromised within a VM might interact with the host system and potentially propagate harmful activities. What strategy should the network administrator employ to mitigate this risk and guarantee the individual VMs' integrity and isolation in the company's virtualized environment?

- Implementing network segmentation
- Establishing firewall rules
- Enforcing user access controls
- Mitigating virtual machine escape ✓ Correct

Explanation

Virtual machine escape is a critical security issue in a virtualized environment, where an application, process, or user within a virtual machine can bypass the virtual machine's barriers and interact directly with the host system.

Network segmentation enhances security but does not directly address a virtual machine escape scenario.

Firewalls mainly govern inbound and outbound network traffic. They do not prevent a virtual machine escape situation.

Enforcing user access controls is primarily about controlling who has access to specific resources within a system or network. It does not directly secure a VM from the possibility of breaking its isolation and interacting with the host system.

Related Content

resources\questions\sy0-701_2_3_003b.question.xml

Question 14 Correct

In a tech company, the IT department is selecting a new vendor to upgrade its network infrastructure. To ensure a smooth and well-defined procurement process, the IT team creates a detailed work order (WO) or statement of work (SOW). After a rigorous selection process, the company chooses the vendor that BEST aligns with its needs. What is the purpose of the WO or SOW in the vendor selection process for the technology company?

- (selected) To define specific requirements and project deliverables expected from the vendor ✓ Correct
- To ensure compliance with industry regulations and standards
- To impose strict limitations on the vendor's pricing
- To provide feedback and evaluations for the vendor's proposals

Explanation

The technology company considers WO or SOW a crucial document in its vendor selection process. Its primary purpose is to define specific requirements and project deliverables clearly.

Although the vendor selection process involves feedback and evaluations, the WO and SOW's focus is specifying the project's requirements and deliverables.

Pricing limitations by the WO or SOW do not apply to the vendor. Instead, its main objective is to outline the work and the desired outcomes without dictating pricing terms.

While regulatory compliance is crucial for the technology company, the WO and SOW's primary objective does not focus on addressing regulatory compliance. Instead, it defines project requirements and deliverables to ensure successful vendor procurement.

Related Content

resources\questions\sy0-701_5_3_004.question.xml

Question 15 Correct

The IT department at a financial institution notices a peculiar trend in its system logs. The system, which generally logs events during regular business hours, has recorded an unusual volume of logs outside these hours. They observe this anomaly despite the company following a detailed security protocol. What is likely the cause of this unusual logging pattern?

- (selected) Out-of-cycle logging ✓ Correct
- Spraying
- Malware attacks
- Incorrect documentation

Explanation

Out-of-cycle logging refers to an anomaly where the log data occurs outside the expected or routine logging cycle. The generated logs occurring at unusual times point toward an out-of-cycle logging issue.

There is no indication that incorrect documentation relates to the issue since the scenario suggests that the company follows a well-documented security protocol.

Malware can cause unusual logging, although the scenario does not provide enough information to definitively link the increased logging with a malware attack.

Spraying is a method attackers use to gain unauthorized access by attempting a common password across many accounts. However, this method is not an indicator of the unusual logging activity described in the scenario.

Related Content

resources\questions\sy0-701_2_4_003b.question.xml

Question 16 Correct

An organization wants to improve the security of sensitive customer information stored on its servers. This sensitive customer information is "data at rest" and not currently accessed or processed. Which method should the organization consider for protecting this data?

- Hashing
- Tokenization
- Obfuscation
- Encryption ✓ Correct

Explanation

Encryption converts data into a coded form (cipher text) that is not easily understood if intercepted. It is a common and effective method for securing data at rest, providing protection against unauthorized access.

Users cannot reverse or decrypt hashed data, which is not ideal for data at rest since they will eventually need to reaccess it.

Payment processing systems often use tokenization, but organizations do not typically use them for protecting data at rest as it can be impractical to tokenize large datasets.

Obfuscation is not as secure or thorough as encryption for protecting data at rest.

Related Content

resources\questions\sy0-701_3_3_001a.question.xml

Question 17 Correct

A large organization protects sensitive data and prevents unauthorized access. The management is implementing a robust security framework to ensure compliance with industry regulations and safeguard critical assets. As part of this initiative, the IT department is drafting a comprehensive set of guidelines and rules that outline the acceptable use of company resources, including networks, computers, and data. These guidelines will create a secure environment by defining the responsibilities and expected behaviors of all employees regarding information security. What is the IT department creating to define the acceptable use of company resources, outline employee responsibilities, and maintain a secure environment?

- Network topology diagrams
- Project management plans
- Incident response procedures
- Information security policies ✓ Correct

Explanation

The IT department is actively creating information security policies. These policies define the acceptable use of company resources, outline employee responsibilities, and maintain a secure environment. Employees must follow these guidelines to ensure the confidentiality, integrity, and availability of sensitive information.

Project management plans focus specifically on managing projects and do not directly address defining acceptable resource use or outlining employee responsibilities for information security.

Incident response procedures concentrate on handling and mitigating security incidents and do not directly relate to defining acceptable resource use or outlining employee responsibilities.

Network topology diagrams visually represent network structures, but they do not have the role of defining acceptable resource use or outlining employee responsibilities for information security.

Related Content

resources\questions\sy0-701_5_1_001a.question.xml

Question 18 Correct

A growing e-commerce company is considering various strategies to ensure its web servers can handle sudden traffic surges without impacting its site's availability. The company is assessing methods that distribute incoming traffic across multiple servers. Which strategy should it implement to dynamically allocate the load based on real-time traffic and server conditions?

- Active server pages
- Passive load balancing
- Active load balancing ✓ Correct
- Active Directory

Explanation

Active load balancing constantly monitors server loads and dynamically distributes client requests across multiple servers based on their real-time conditions and capacities. This process is an effective strategy to manage sudden traffic surges and maintain high availability.

Passive load balancing distributes client requests evenly across servers without considering their current loads.

Active server pages are a server-side scripting technology that creates dynamic web pages. While it can improve the website's functionality, it does not directly impact server load distribution.

Active Directory is a service for managing network domains and resources. While it's a crucial component in many networks, it doesn't contribute to load balancing or handling traffic surges.

Related Content

resources\questions\sy0-701_5_5_001a.question.xml

Question 19 Correct

A systems engineer at a company is designing a new data-handling process. The engineer plans to employ a technique that can help ensure data integrity and provide a quick way to check if anyone has recently tampered with the data. However, the engineer is also aware that this method can potentially reveal patterns in the data if not used correctly. What technique is the systems engineer considering?

- Tokenization
- Hashing ✓ Correct
- Obfuscation
- Encryption

Explanation

Hashing verifies data integrity by generating a unique hash value for a given set of data. If the data changes, so does the hash, which quickly indicates altered data or verifies data integrity.

Encryption transforms data into a coded version to prevent unauthorized access and does not directly offer a means to verify data integrity like hashing does.

Tokenization replaces sensitive data with nonsensitive tokens instead of verifying data integrity.

Obfuscation is the process of obscuring code to make it difficult to understand or find, usually to deter reverse engineering attempts rather than to maintain data integrity.

Related Content

resources\questions\q_pt_sy0-701_3_3_009.question.xml

Question 20 Correct

A healthcare organization is strengthening its data protection framework to ensure compliance with local and international regulations. One focus area is clearly defining the roles and responsibilities between the data controllers and processors, as this impacts the overall management and protection of sensitive data. In this scenario, which two statements accurately outline the responsibilities of the data controller and the data processor regarding data protection? (Select the two best options.)

- [ ] Data controller—performs day-to-day operations on data
- [x] Data controller—determines the purposes for which data is processed ✓ Correct
- [x] Data processor—processes data on behalf of the controller ✓ Correct
- [ ] Data processor—decides the purpose of data processing

Explanation

A data controller is primarily responsible for determining the purpose of processing the data, which guides the organization.

On the other hand, the data processor processes the data on behalf of the data controller, following the guidelines the controller provides.

The responsibility of performing day-to-day operations, such as data storage or management, typically falls under the role of the data processor, not the controller.

The data processor does not decide the purpose of data processing. This responsibility belongs to the data controller. The processor operates under the direction of the controller.

Related Content

resources\questions\q_pt_sy0-701_5_1_003.question.xml

Question 21 Correct

A financial institution has recently undergone a significant network infrastructure upgrade and plans to enhance its network security. It is considering incorporating access control lists (ACLs) into its firewall rules and wants to establish a screened subnet for better security. Which of the following options would be the MOST beneficial course of action?

- Establish a screened subnet but keep the existing firewall rules
- Incorporate ACLs into its firewall rules and set up a screened subnet ✓ Correct
- Maintain the existing firewall rules and ignore ACLs and screened subnet
- Implement ACLs in its firewall and avoid creating a screened subnet

Explanation

Incorporating ACLs into the institution's firewall rules will provide more precise control over traffic based on various parameters. Simultaneously, setting up a screened subnet can isolate public-facing servers from sensitive internal network resources, thus reducing the exposure of the internal network to external threats.

Keeping the current firewall rules without considering ACLs or a screened subnet may leave the institution vulnerable to more advanced threats.

While implementing ACLs in the firewall enhances traffic control and security, not setting up a screened subnet misses an opportunity to reduce the exposure of internal network resources to external threats.

Establishing a screened subnet is a good security practice; however, keeping the existing firewall rules without integrating ACLs misses out on granular traffic control.

Related Content

resources\questions\sy0-701_4_5_004.question.xml

Question 22 Correct

A cyber technician updates the standard operating procedure on digital forensic evidence collection. In the spirit of digital forensics, what is the process of obtaining a forensically clean copy of data from a seized device as evidence?

- (selected) Acquisition ✓ Correct
- Reporting
- Analysis
- Preservation

Explanation

Acquisition is obtaining a forensically clean copy of data from a device seized as evidence. If the organization does not own the computer system or device, there is the question of whether search or seizure is legally valid.

Analysis is not associated with collecting digital forensics. It occurs when the first responder analyzes the data to determine whether it identified a genuine incident and assigns the appropriate priority level.

Preservation is the assurance of safeguarding the obtained information from tampering and retains its' purity throughout the evidence collection process.

Digital forensics reporting summarizes the significant contents of the digital data and the conclusions from the investigator's analysis.

Related Content

resources\questions\sy0-701_4_8_010.question.xml

Question 23 Correct

The IT department of a medium-sized company is preparing to implement a new wireless network to enhance mobility and productivity within the workplace. The IT team has conducted an in-depth analysis of the office layout and user requirements and now faces the task of strategically positioning the wireless access points (WAPs) throughout the office. The team understands the potential risks and challenges involved in wireless deployments. Which considerations should the IT team take into account when strategically positioning the wireless access points (WAPs) in the company's new wireless network? (Select the two best options.)

- [x] Minimizing interference from nearby electronic devices to enhance network performance ✓ Correct
- [x] Optimal coverage of the office area to ensure reliable connectivity for all users ✓ Correct
- [ ] Ensuring the WAPs are accessible only to employees with specific job roles and responsibilities
- [ ] Positioning WAPs based on the design preferences of the company's management

Explanation

Strategically positioning the wireless access points (WAPs) to achieve optimal coverage is essential to ensure reliable connectivity for all users throughout the office and eliminate potential dead zones in every corner of the workplace.

Minimizing interference from nearby electronic devices is crucial for enhancing network performance and reducing connectivity issues. To mitigate this, the IT team should identify potential sources of interference and strategically place the WAPs away from these devices.

Network performance and coverage should take precedence over design preferences to ensure optimal connectivity and productivity.

Access control measures determine who can connect to the wireless network and what level of privileges they have. While important for network security, this consideration is distinct from the physical placement of WAPs.

Related Content

resources\questions\sy0-701_4_1_003a.question.xml

Question 24 Correct

Which type of application vulnerability can refer to software flaws associated with the timing or order of events within a software program, which can cause undesirable or unpredictable outcomes through manipulation?

- Buffer overflow
- Malicious update
- Race conditions ✓ Correct
- Memory injection

Explanation

Application race condition vulnerabilities refer to software flaws associated with the timing or order of events within a software program, which can cause undesirable or unpredictable outcomes through manipulation.

Memory injection vulnerabilities refer to a type of security flaw where an attacker can introduce (inject) malicious code into a running application's process memory.

To exploit a buffer overflow vulnerability, the attacker passes data that deliberately flood a space of temporary memory.

A malicious update refers to an update that appears legitimate but contains harmful code, often used by cybercriminals to distribute malware or execute a cyberattack.

Related Content

resources\questions\q_pt_sy0-701_2_3_001.question.xml

Question 25 Correct

A company had data for an upcoming project stolen and leaked online. The investigation implies that social engineering is the cause. Which policy can prevent such an incident from occurring?

- Fair use
- Clean desk ✓ Correct
- Standard operating procedure (SOP)
- Non-disclosure agreement (NDA)

Explanation

A clean desk policy means an employee's work area should be free from documents or information. The policy aims to prevent sensitive information from prying eyes.

A fair use (or acceptable use) policy defines what someone can do while using a particular service or resource (such as using systems at a business).

A standard operating procedure (SOP) is a documented list of steps or actions to perform a task to a specified and expected standard.

A non-disclosure agreement (NDA) is a document between parties (such as an employer and employee) for a legal basis in protecting information assets.

Related Content

resources\questions\sy0-701_5_6_010.question.xml

Question 26 Correct

A nationwide company is preparing to overhaul its encryption protocols due to newly released options that can quickly protect all data. It is leaning towards an encryption standard that will allow faster processing as it does not require Operating System intervention to encrypt the data. What standard will the company be employing?

- Key-encryption key
- Self-encrypting drives ✓ Correct
- Full Disk Encryption
- Opal Storage Specification

Explanation

Self-encrypting drives (SED) automatically encrypt all data written to it. They are more efficient than Full Disk Encryption (FDE), as the drive controller performs the cryptographic operations.

FDE refers to encrypting the entire contents of the drive (or volume), including system files and folders. The operating system (OS) completes this encryption and results in a degradation in performance.

Key-encryption key (KEK) is the component used to encrypt the data encryption key (DEK). The user password unlocks the DEK during the SED process. KEK is a more efficient way to encrypt data, but it is not the whole process.

Opal Storage Specification is the standard that replaced proprietary mechanisms for encryption and helps with encryption on disks.

Related Content

resources\questions\q_pt_sy0-701_2_5_003.question.xml

Question 27 Correct

A popular entertainment company is onboarding a new employee. The company has completed preliminary interview steps and due diligence. Internal security is extremely important, so their human resources department is preparing documentation for the formal employment process. In implementing the process, which solution would help limit the risk of proprietary data that an employee outside the company can use?

- Background check
- Non-Disclosure Agreement (NDA) ✓ Correct
- Analysis and identification
- Identity and Access Management (IAM)

Explanation

When an employee or contractor signs an NDA, they confirm they will not share confidential information with a third party. Signing this type of contract legally protects internal intellectual property.

IAM refers to creating an account for the user to access the computer system with the appropriate privileges.

The background check process essentially determines that a person is who they say they are and are not concealing criminal activity, bankruptcy, or connections that would make them unsuitable or risky employees.

Analysis and identification are a part of the incident lifecycle. During this phase, the identification of a threat can occur.

Related Content

resources\questions\sy0-701_5_3_011.question.xml

Question 28 Correct

After an unauthorized access incident in the server room over the weekend, the IT department of a company decides to implement new security controls to deter similar future incidents. Which of the following should they implement?

- Applying reflective window film to the server room windows
- Installing a network-connected smoke detector system in the server room
- Introducing a key control system for office desks
- Placing visible signs indicating surveillance and severe penalties for unauthorized entry ✓ Correct

Explanation

Placing visible signs indicating surveillance and severe penalties for unauthorized entry is an example of a physical control. This kind of deterrence can discourage unauthorized physical access by setting clear consequences.

Installing a network-connected smoke detector system in the server room is a physical control, but it's designed to detect fire hazards, not deter unauthorized access.

Applying reflective window film to the server room windows is a physical control aimed at enhancing privacy, but it doesn't deter unauthorized access once inside the building.

Introducing a key control system for office desks is a physical control, but it's more relevant for securing individual workstations and personal belongings than deterring unauthorized access to a server room.

Related Content

resources\questions\q_sy0-701_1_1_003a.question.xml

Question 29 Correct

In a cybersecurity firm, the IT department is preparing for a penetration testing engagement to assess the organization's security posture. The team has decided to conduct an external penetration test on the company's public-facing web applications and networks. The primary goal is to identify vulnerabilities and potential entry points for attackers. To ensure a smooth testing process and avoid misunderstandings, the IT team has collaborated with the company's management and relevant stakeholders to establish the assessment's rules of engagement (ROE). What is the purpose of establishing ROE in a penetration testing engagement?

- To allow penetration testers unrestricted access to all systems and data within the organization
- To ensure the penetration test results are shared with external parties to strengthen collaboration
- To define the scope of the assessment, testing methods, and timeframe for conducting the test ✓ Correct
- To eliminate all security vulnerabilities identified during the testing process

Explanation

Establishing rules of engagement (ROE) in a penetration testing engagement is essential to define the assessment's scope, testing methods, and timeframe. The IT team uses ROE to prevent unintended disruptions to critical services and ensure a smooth testing process.

Although collaboration is important, the primary purpose of ROE is to establish the parameters and scope of the testing.

During the penetration test, ROE imposes limitations on accessing certain resources to prevent unauthorized access to sensitive information or systems.

The main goal of penetration testing is to identify vulnerabilities, not eliminate them. The focus is on discovering weaknesses for remediation rather than fixing them during the assessment.

Related Content

resources\questions\sy0-701_5_3_001a.question.xml

Question 30 ✕ Incorrect

An organization aims to improve the security of its network infrastructure by limiting unauthorized access to sensitive data on employees' smartphones, especially in cases of loss or theft. What network infrastructure component should the organization implement to achieve this goal?

- (●) Wireless access point ✕ Incorrect
- ( ) Ethernet switch
- ( ) Router ✓ Correct
- ( ) Domain name system (DNS) server

Explanation

A router would be the most suitable network infrastructure component in this scenario. In the context of mobile device security, a network administrator can configure routers to limit access to specific network segments, thus adding a layer of security.

An Ethernet switch is important for network communication, but switches would not directly contribute to securing mobile devices against unauthorized access.

Wireless access points operate at Layer 2, providing a bridge between a cabled network and wireless devices. They would not offer specific protection for mobile devices in case of loss or theft.

A DNS server allows applications and users to address hosts and services. DNS servers do not directly protect against unauthorized access to mobile devices.

Related Content

resources\questions\sy0-701_3_1_015.question.xml

Question 31 Correct

What type of threat actor will attempt to exploit their authorized access within an organization for revenge or financial gain?

- Unskilled attacker
- Nation-state
- Hacktivist
- Insider threat ✓ Correct

Explanation

Insider threats are individuals or groups with authorized access to an organization's systems and data. They could potentially misuse their access for malicious purposes. Insider threats can include employees, contractors, or any other individuals granted internal access.

Hacktivists are politically motivated cyber attackers. They do not usually have authorized access to an organization's systems or data.

Governments support nation-state actors that engage in highly sophisticated cyberattacks. They typically do not have authorized access to an organization's systems.

Unskilled attackers often use readily available tools to perform cyberattacks and generally do not have authorized access to an organization's systems.

Related Content

resources\questions\q_sy0-701_2_1_004b.question.xml

Question 32 Correct

A growing e-commerce company wants to implement a strategy that evenly distributes incoming traffic across multiple servers without constantly monitoring server loads or making adjustments based on real-time conditions. Which strategy should it implement to manage load distribution in this manner?

- Active Server Pages
- Passive load balancing ✓ Correct
- Active Directory
- Active load balancing

Explanation

Passive load balancing distributes client requests evenly across servers without considering their current loads. This method aligns with the company's desire to manage load distribution without constantly monitoring real-time conditions.

Active Directory is a service for managing network domains and resources. While essential in many networks, it doesn't contribute to load balancing or managing traffic surges.

Active Server Pages are a server-side scripting technology that creates dynamic web pages. They can enhance a website's functionality but do not directly impact server load distribution.

Active load balancing monitors server loads, dynamically distributing client requests based on real-time conditions. While effective for managing traffic surges, this approach does not align with the company's preference for an even distribution method without real-time adjustments.

Related Content

resources\questions\sy0-701_5_5_001b.question.xml

Question 33 Correct

Which type of threat actor is MOST likely to engage in cyber espionage with strategic or political motivations?

- Hacktivist
- Organized crime
- Competitors
- Nation-state ✓ Correct

Explanation

Nation-state actors often have the support of governments. Their activities, including cyber espionage, are typically motivated by strategic or political reasons.

Competitors might engage in cyber espionage against their rivals but are generally motivated by business competitiveness, not strategic or political reasons.

Hacktivists use hacking to express or promote a political agenda, but they are not typically involved in state-level strategic or political cyber espionage.

Organized crime groups engage in cybercrime activities like financial fraud, blackmail, or extortion for profit. They are typically not involved in strategic or political cyber espionage.

Related Content

resources\questions\q_sy0-701_2_1_006.question.xml

Question 34 Correct

What social engineering technique occurs when a threat actor assumes the identity of a remote sales representative and contacts the help desk to urgently or authoritatively obtain login credentials for remote access?

- Brand impersonation
- Watering hole attack
- Phishing
- Pretexting ✓ Correct

Explanation

Pretexting is a social engineering tactic where a threat actor deceives a target into sharing sensitive information.

Phishing involves sending deceptive emails with disguised links to trick users into interacting with a spoofed website. However, it does not explicitly include posing as a sales representative or contacting the help desk.

A watering hole attack infiltrates a commonly used third-party website to infect devices without posing as a sales agent or contacting support.

Brand impersonation is copying a company's logos and format to create a convincing phishing message or website. It doesn't involve pretending to be a representative or contacting the help desk.

Related Content

resources\questions\q_sy0-701_2_2_002a.question.xml

Question 35 Correct

A cyber group is reviewing its web filtering capabilities after a recent breach. Which centralized web-filtering technique groups websites into categories such as social networking, gambling, and webmail?

- Block rules
- Content categorization ✓ Correct
- Reputation-based filtering
- Uniform resource locators (URL) scanning

Explanation

Content categorization classifies websites into categories such as social networking, gambling, adult content, webmail, and many others.

Block rules stem from various factors such as the website's Uniform Resource Locators (URL), domain, Internet Protocol (IP) address, content category, or even specific keywords within the web content.

Reputation-based filtering leverages continually updated databases that score websites based on their observed behavior and history.

URL scanning is a method that protects web traffic as the proxy server examines the URLs requested by users and can block access to specific URLs known to host malicious content, are inappropriate, or violate the company's Internet usage policy.

Related Content

resources\questions\q_pt_sy0-701_4_5_001.question.xml

Question 36

Incorrect

Instructions

Based on the scenario, use the **dropdown selectors** to address the requirements and considerations for cloud migration options. Then, use the **radio selectors** to indicate if the statements are true or false.

Mitigating Data Breaches

Which option can better minimize the risk of data breaches? Select

Data Privacy

Which option is better suited for ensuring data privacy for sensitive patient records? Select

Regulatory Compliance

Statement	True	False
Option A automatically encrypts data at rest and in transit.		
Option B may require more detailed security configuration due to its architecture.		
Vendor lock-in can significantly impact an organization's ability to		

You got **0** out of **9** correct.

Less

Option A offers automated security updates and patches, reducing the likelihood of vulnerabilities that could lead to data breaches.

Option B provides granular control over data, allowing for enhanced data privacy measures, especially for sensitive patient records.

Option B allows for features like role-based access control and data masking, making it more aligned with healthcare industry regulations without relying on the vendor.

Option A relies on the vendor for automated security updates and patches, making it more dependent on vendor reliability.

Option A offers automated encryption for data at rest and in transit, enhancing data security.

Related Content

pbq_practice_3.question.fex

Question 37 Correct

In a medium-sized company, the IT security team implements Privileged Access Management (PAM) tools to enhance security measures. The team is considering using just-in-time (JIT) permissions to reduce the risk of unauthorized access to critical systems and sensitive data. JIT permissions allow users to obtain temporary access only when necessary, minimizing the exposure of privileged accounts. The team is aware that this approach can significantly improve security by limiting the window of opportunity for potential attackers. Which statement regarding JIT permissions and PAM tools are correct?

- (selected) JIT permissions reduce the risk of unauthorized access by granting temporary access only when necessary. ✓ Correct
- JIT permissions provide users with permanent access to critical systems and sensitive data.
- PAM tools are primarily focused on managing standard user permissions.
- JIT permissions are not suitable for enhancing security in medium-sized companies.

Explanation

Just-in-time (JIT) permissions reduce the risk of unauthorized access by granting temporary access only when necessary. This process minimizes the window of opportunity for potential attackers to exploit privileged accounts.

Just-in-time (JIT) permissions do not provide users with permanent access. Instead, they grant temporary access to critical systems and sensitive data, limiting the exposure of privileged accounts.

Privileged access management (PAM) tools focus on managing and securing privileged user accounts, not standard user permissions.

Just-in-time (JIT) permissions are suitable for enhancing security in companies of all sizes, including medium-sized companies. It is a valuable security measure to limit exposure and reduce attack surfaces, regardless of the organization's size.

Related Content

resources\questions\sy0-701_4_6_010.question.xml

Question 38 Correct

A healthcare organization is setting up a system to store patient passwords securely. To ensure that only authorized personnel can verify the passwords and the system cannot be compromised during a breach, which technique should the organization implement?

- Tokenization
- Hashing ✓ Correct
- Asymmetric encryption
- Symmetric encryption

Explanation

Hashing transforms plaintext passwords into a fixed-size text string, known as a hash value. In the context of the healthcare organization, hashing ensures that passwords are securely stored and can be verified without revealing the original passwords, even if unauthorized personnel gain access to the hashed data.

Symmetric encryption is susceptible to decryption and becomes accessible if a threat actor discovers the key, making it less effective than hashing the data.

Asymmetric encryption is vulnerable if a threat actor discovers the private key, making it less effective than hashing the data.

Tokenization primarily protects data in transit and would not necessarily be the best choice for storing patient data securely within a system.

Related Content

resources\questions\q_pt_sy0-701_3_3_004.question.xml

Question 39 Correct

A rapidly growing e-commerce company is considering changes to its current on-premises network infrastructure to handle increasing workloads better and provide high availability. The company expresses concerns about the potential costs and complexity associated with scalability and ease of recovery from potential failures. Which infrastructure options should the company consider to address its needs?

- Maintain the on-premises network and simply add more server nodes as the workload increases.
- Distribute the workload across several smaller, geographically dispersed on-premises sites.
- Switch to a cloud networking solution with a well-defined service-level agreement (SLA).
- Implement a hybrid solution with a mix of on-premises and cloud-based infrastructure. ✓ Correct

Explanation

A hybrid solution can offer the best of both worlds, allowing the company to maintain some on-premises infrastructure while also taking advantage of the scalability and resilience of cloud-based solutions. The on-premises infrastructure can handle critical tasks, while the cloud-based infrastructure can be rapidly scaled up or down as required.

While maintaining an on-premise network seems feasible in the short term, it doesn't adequately address the company's concern about scalability and recovery from potential failures.

Switching completely to a cloud-based solution might also introduce new risks and dependencies, as the company would rely solely on the cloud provider for its network infrastructure.

Over-distribution to multiple smaller sites introduces new challenges and costs associated with managing and maintaining multiple sites.

Related Content

resources\questions\q_pt_sy0-701_3_2_001.question.xml

Question 40 Correct

A company using Wi-Fi Protected Access (WPA) wireless security on their wireless access points (WAPs) uses Lightweight Extensible Authentication Protocol (LEAP) to authenticate users to the network. LEAP is vulnerable to password cracking. What other options does the company have to mitigate this vulnerability? (Select the two best options.)

- [ ] EAP-MD5
- [x] Protected Extensible Authentication Protocol (PEAP) ✓ Correct
- [x] Flexible Authentication via Secure Tunneling (EAP-FAST) ✓ Correct
- [ ] RADIUS federation

Explanation

Flexible Authentication via Secure Tunneling (EAP-FAST) is Cisco's replacement for LEAP. It addresses LEAP vulnerabilities using Transport Layer Security (TLS) with Protected Access Credential (PAC) instead of certificates.

Protected Extensible Authentication Protocol (PEAP) uses a server-side public key certificate to create an encrypted tunnel between the supplicant and authentication server. This protocol is an industry standard.

EAP-MD5 is a secure hash of a password sent to the authenticating server. EAP-MD5 does not provide mutual authentication from the client to the supplicant.

RADIUS federation means multiple organizations allow access to each other's users by joining their RADIUS servers into a RADIUS hierarchy. This access is not required in this case and does not help the mitigation.

Related Content

resources\questions\sy0-701_2_2_016.question.xml

Question 41 Correct

The IT team at a medium-sized company is upgrading its wireless network security to protect sensitive data and ensure secure communication between devices. They have decided to implement a Wi-Fi Protected Access 3 (WPA3). What is the primary purpose of implementing WPA3 on the company's wireless network?

- To increase the wireless network's speed and performance
- To enhance wireless network security with the latest encryption standards ✓ Correct
- To ensure seamless compatibility with legacy wireless devices
- To provide additional administrative features for network management

Explanation

Implementing Wi-Fi Protected Access 3 (WPA3) on the company's wireless network is to enhance security by utilizing the latest encryption standards. WPA3 provides strong encryption mechanisms, making it more resistant to various security threats and attacks.

While WPA3 enhances security, it does not directly impact the speed or performance of the wireless network. Its primary focus is on providing robust encryption to safeguard data.

While WPA3 is backward compatible with WPA2, its primary purpose is not to ensure compatibility with legacy wireless devices. Instead, it focuses on strengthening security through advanced encryption methods.

WPA3 enhances security, not additional administrative features. Its main function is to protect data using robust cryptographic protocols.

Related Content

resources\questions\sy0-701_4_1_005.question.xml

Question 42 Correct

An organization's IT security team has discovered that a recent software update, unknowingly deployed, contained a zero-day exploit. This vulnerability has now made the company's systems susceptible to potential unauthorized access. Which of the following immediate actions should the security team execute to manage this zero-day exploit situation?

- Disconnect the company's entire network from the internet.
- Reformat all affected systems and restore data from backup.
- Isolate the impacted systems and apply a patch or remediation strategy. ✓ Correct
- Contact all clients and inform them about the security breach.

Explanation

Isolating the impacted systems and applying a patch or remediation strategy helps contain the threat and initiates remediation processes.

Disconnecting the company's entire network from the Internet may disrupt essential services and business operations. While this action might be necessary in some extreme situations, it should not be the immediate response to a zero-day exploit.

Reformatting all affected systems and restoring data from the backup is an extensive and time-consuming process.

Contacting all clients and informing them about the security breach should occur only after fully understanding the breach and its implications. Immediate communication without complete information can lead to unnecessary panic and potential reputational damage.

Related Content

8.1.2 Vulnerability Types

8.1.3 Zero-Day Vulnerabilities

resources\questions\q_pt_sy0-701_2_3_004.question.xml

Question 43 Correct

To address the escalating operational costs and complexities stemming from multiple standalone applications, an organization plans to restructure its software deployment process. They want to minimize overhead, increase flexibility in development environments, and enhance the efficient use of system resources. What approach would be the MOST effective?

- Virtualization
- Hybrid cloud infrastructure
- Containerization ✓ Correct
- Microservices

Explanation

Containerization encapsulates applications and their dependencies, which provides the flexibility to run them across different environments. It also allows for better resource utilization, as each container only holds the application and its related binaries/libraries, effectively reducing overhead.

Virtualization can provide some cost savings and flexibility but generally consumes more resources than containerization, as each virtual machine requires its own operating system.

Microservices bring flexibility and go in a container, but they do not directly lead to better resource utilization, as they do not impact how applications use system resources.

Hybrid cloud infrastructure provides scalability and potential cost savings but does not enhance the efficient use of current system resources.

Related Content

resources\questions\q_pt_sy0-701_3_1_004.question.xml

Question 44 Correct

A senior security analyst is refining the incident response processes for a large organization that recently implemented a Security Information and Event Management (SIEM) system. During a simulation of a cybersecurity incident, the analyst observed that the SIEM system generated several alerts that were false positives, leading to unnecessary consumption of resources. On which step should the analyst focus to improve the efficiency of the alert response and remediation process?

- Implementing additional threat intelligence feeds in the SIEM system
- Increasing the number of correlation rules in the SIEM system
- Enhancing the validation and quarantine processes in the alert response ✓ Correct
- Increasing the frequency of SIEM system reporting to capture more incidents

Explanation

The analyst should focus on enhancing validation and quarantine processes in alert response. Validation reduces false positives, while quarantine isolates the source of indicators to manage potential incidents.

Simply increasing the number of correlation rules in the SIEM system is not the right solution, as it could lead to more false positives if not done judiciously.

Adding additional threat intelligence feeds in the SIEM system does not directly address false positives and could cause data overload and more false positives.

Increasing SIEM system reporting frequency does not directly improve alert response and remediation efficiency, as it does not address false positives in alerting.

Related Content

resources\questions\sy0-701_4_4_006.question.xml

Question 45 ✕ Incorrect

A company has noticed increasing attacks on its employees via phishing emails and impersonation calls. These attacks have led to unauthorized access to sensitive data and a loss of customer trust. What method should the company implement to counteract these malicious efforts?

- [ ] Strengthen password policies ✓ Correct
- [x] Conduct social engineering awareness training ✓ Correct
- [ ] Implement the execution phase
- [ ] Implement network segmentation

Explanation

Conducting social engineering awareness training empowers employees to recognize and resist attempts to manipulate them through phishing, pretexting, or other deceptive practices.

Strengthening password policies can add a layer of protection against the described attacks. Even if an attacker successfully gains access to credentials through social engineering, strong, unique passwords can make it more challenging for the attacker to misuse them.

Focusing on the execution phase, typically associated with carrying out a project's planned activities, does not counteract social engineering tactics used to exploit human vulnerabilities.

Implementing network segmentation enhances security by isolating network parts and limiting access between them. This step would protect other systems but not prevent initial access.

Related Content

resources\questions\q_pt_sy0-701_5_6_005.question.xml

Question 46 Correct

A healthcare organization is enhancing patient privacy and elects to use an obfuscation for social security numbers to replace the first five digits with "XXX-XX." What type of obfuscation is the organization using to conceal personal data?

- Steganography
- Salting
- Data masking ✓ Correct
- Tokenization

Explanation

Here, the organization is masking data, which occurs when a user redacts all or part of the contents of a database field by substituting the string, such as using "x" in its place.

Salting is a cryptography hash method where the user hashes data used for something like a password, and the system cannot decrypt it back to the plaintext password that generated it.

Steganography occurs when a user embeds information, such as a document, within an unexpected source, such as a message hidden in a picture, to guise its true appearance.

Tokenization occurs when a randomly generated token replaces all or part of the value of a database field while maintaining the original data on a separate token server.

Related Content

resources\questions\q_pt_sy0-701_1_4_001.question.xml

Question 47 Correct

A cyber engineer enhances processes and controls surrounding exposures and vulnerabilities to meet all regulatory requirements before a year-end inspection. What focuses on key aspects of the organization's cybersecurity strategy, including prioritization, considerations of exposure, and risk tolerance contexts?

- Common Vulnerability Scoring System (CVSS)
- Vulnerability analysis ✓ Correct
- open-source intelligence (OSINT)
- Common Vulnerabilities and Exposures (CVE)

Explanation

Here, vulnerability analysis is critical in supporting several key aspects of an organization's cybersecurity strategy, including prioritization, vulnerability classification, exposure considerations, organizational impact, and risk tolerance contexts.

Not best suited for this scenario, open-source intelligence describes collecting and analyzing publicly available information and using it to support decision-making.

Additionally, the Common Vulnerability Scoring System (CVSS) is the product of the Forum of Incident Response and Security Teams, and its metrics generate a score from 0 to 10 based on vulnerability characteristics.

Common Vulnerabilities and Exposures (CVE) is a dictionary of vulnerabilities in published operating systems and applications software and provides the principal input for NIST's National Vulnerability Database.

Related Content

resources\questions\q_pt_sy0-701_4_3_001.question.xml

Question 48 Correct

A company mandated personnel training within each business unit on their own unit's role in the incident response plan. However, during an incident response, it became apparent that the business units were not working well together, resulting in a delayed resolution. How can the company build a more unified response to an incident? (Select the two best options.)

- [ ] More department training
- [x] Team building exercises ✓ Correct
- [ ] Leaders only training
- [x] Cross-team training ✓ Correct

Explanation

Team building exercises help to foster camaraderie between business units, and the working relationships built from these exercises will help the units function better during an incident.

Cross-team building exercises and training will help business units understand the other units' capabilities and how they can be supportive during a live incident response.

More department training will not resolve the problems of poor working conditions amongst the various business units. It can potentially increase the problems.

Training for just leaders will not help all personnel assigned to the various business units function as a more cohesive team. Leader-only training would do nothing to decrease the time to resolution during a live incident.

Related Content

resources\questions\q_pt_sy0-701_4_8_003.question.xml

Question 49 Correct

A cyber consultant uses a sandbox environment to test some malware recently found on a company laptop. What malware can deliver as the payload for an exploit of a severe vulnerability and able to execute without requiring any authorization using SYSTEM privileges?

- Virus
- Keylogger
- Logic bomb
- Rootkit ✓ Correct

Explanation

Rootkit is the level at which malware can deliver as the payload for an exploit of a severe vulnerability. A rootkit executes without requiring any authorization using the computer system's privileges.

A computer virus is malware that replicates and spreads from computer to computer, usually by "infecting" executable applications or program code.

Keylogger is spyware that actively attempts to steal confidential information by recording keystrokes. The attacker usually hopes to discover passwords or credit card data.

Some types of malware do not trigger automatically. Having infected a system, they wait for a preconfigured time or date (time bomb) or a system or user event (logic bomb).

Related Content

resources\questions\sy0-701_2_4_017.question.xml

Question 50 ✕ Incorrect

An organization plans to implement a load balancer as part of its network infrastructure to manage the increased web traffic to its services. The organization tasks a network administrator with ensuring that the load balancer configures in line with best security practices to reduce the attack surface and secure the enterprise infrastructure. The network administrator's responsibilities include evaluating the network appliances, securing connectivity, and considering device placement. What is the MOST effective security measure in this scenario?

- ○ Configure the load balancer to operate in a fail-open mode.
- ◉ Place the load balancer in the screened subnet. ✕ Incorrect
- ○ Use a proxy server in combination with the load balancer.
- ○ Implement a Web Application Firewall (WAF) alongside the load balancer. ✓ Correct

Explanation

A WAF with a load balancer provides robust security by inspecting web traffic and mitigating threats such as SQL injection and Cross-Site Scripting.

Configuring the load balancer to operate in a fail-open mode ensures service continuity but may expose the network to potential security risks if the device fails, making this choice less optimal.

Using a proxy server with the load balancer does not offer the most comprehensive security measure compared to other options.

Placing the load balancer in the screened subnet is a good security practice but does not directly address potentially exploited web application vulnerabilities via increased web traffic.

Related Content

resources\questions\q_pt_sy0-701_3_2_007.question.xml

Question 51 Correct

Planning to store data from various global branches, an international company is assessing the legal and regulatory compliance requirements for data storage and usage. What should the organization consider in its analysis of government requirements?

- Local privacy laws
- Geographic restrictions
- Data transfer rules
- Data sovereignty ✓ Correct

Explanation

Data sovereignty is the concept that data is subject to the laws and governance structures within the nation the company collects data. Complying with data sovereignty laws is crucial for an international company storing data from different locations.

Data transfer rules refer to the regulations governing the movement of data. The primary concern for an international company would be the specific laws in each country where it stores data.

Local privacy laws are a part of the considerations under data sovereignty. However, data sovereignty encompasses more than just local privacy laws.

Geographic restrictions refer to data management limitations based on geographic location. The term does not encapsulate the full range of legal and regulatory considerations.

Related Content

resources\questions\sy0-701_3_3_008.question.xml

Question 52 Correct

A company's web server is openly accessible to the internet, demanding heightened security measures. Considering the need for essential protocols and the introduction of a screened subnet, how should the company configure the firewall's access control lists (ACLs)?

- Permit Hypertext Transfer Protocol (HTTP) and Hypertext Transfer Protocol Secure (HTTPS) on firewall access control lists (ACLs); establish a screened subnet for the web server. ✓ Correct
- Permit only FTP, SSH, and enable File Integrity Monitoring; disregard screened subnet implementation.
- Block all ports and protocols; enable a screened subnet for the server.
- Allow all ports and protocols; do not create a screened subnet.

Explanation

Permitting Hypertext Transfer Protocol (HTTP) and Hypertext Transfer Protocol Secure (HTTPS) on the firewall ACLs establishes a screened subnet and adds a layer of security by isolating the server from the internal network, minimizing potential damage from a breach.

Blocking all ports and protocols would hinder the web server's operation. Although a screened subnet would add a layer of security, it doesn't replace the need for well-configured ACLs.

Allowing all ports and protocols introduces unnecessary security risks. Foregoing the creation of a screened subnet misses a crucial opportunity to further isolate and protect the server.

Permitting only FTP and SSH on the firewall ACLs without a screened subnet lacks comprehensive security.

Related Content

resources\questions\sy0-701_4_5_006.question.xml

Question 53 Correct

A software company has completed in-house testing and auditing and is bringing in an outside source to attempt to compromise the new software. The project head wants to ensure that the MOST realistic testing goes against the software. What type of penetration testing will the outside source use on this new software?

- Environmental variables
- Known environment
- Unknown environment ✓ Correct
- Partially known environment

Explanation

In an unknown environment, the contractor has no information about the software and performs extensive reconnaissance to attempt an attack on the software as an external threat would.

Known environment, the contractor has all the information about the software and uses this to compromise the application. This process is an example of an insider threat to the software.

In a partially known environment test, the contractor has some information about the software but will still need to perform reconnaissance.

Environmental variables related to vulnerability analysis refer to the systems and software a company has currently in use. Age and diversity, as well as complexity, are all variables. This process is not a software test.

Related Content

resources\questions\sy0-701_4_3_011.question.xml

Question 54 Correct

A board of directors is discussing vulnerability response as a recent breach significantly impacts their semi-annual earnings. What remediation practice can provide future financial protection in the event of another security breach?

- Compensating controls
- Patching
- Insurance ✓ Correct
- Segmentation

Explanation

Insurance provides financial protection in case of a security breach resulting from a vulnerability and is important in a comprehensive risk management strategy, complementing technical controls with financial risk transfer.

Not associated with this scenario, segmentation involves dividing a network into separate pieces to contain potential security breaches.

Additionally, compensating controls refer to measures put in place to mitigate the risk of a vulnerability when security teams cannot directly eliminate it or when direct remediation is not immediately possible.

Patching is one of the most straightforward and effective remediation practices. It involves applying updates and patches to software or systems to fix known vulnerabilities.

Related Content

resources\questions\sy0-701_4_3_014.question.xml

Question 55

Incorrect

Instructions

Based on the information provided in the tickets, use the **dropdown selectors** in each of the service tickets to select the appropriate diagnosis, adversary tactic used, and adversary tactic used.

Open **Service Ticket #2715** Date: 7/13/2023 Submitted By: Edgar Rona

Service Ticket: #2715. Open Date: 7/13/2023 Submitted By: Edgar Rona (Finance)
Message: I received an email from what I thought was Microsoft instructing me to download an application that would help make my PC run more optimally. I downloaded the application and installed it, but since then I've noticed my PC is running slower and has frozen several times. I'm concerned there may be a virus.

Updated: 7/14/2023 Notes (Tier 1 Support): Found DNS (hosts file) to be misconfigured with malicious entries.

Diagnosis Select Adversary Tactic Select Mitigation Select

Open **Service Ticket #2723** Date: 7/16/2023 Submitted By: Zoey Smithson

Service Ticket: #2723. Open Date: 7/16/2023 Submitted By: Zoey Smithson (Admin Assistant)
Message: I received a call from human resources. She was trying to get her faxes working but nothing seemed to help. I'm new here and wanted to make a good impression and told her I would help. She sent me a file she needed to be faxed ASAP. I opened it and there was no document. I'm not sure if it's related, but ever since then, my computer reboots and I keep losing my work!

Updated: 7/17/2023 Notes (Tier 1 Support): Found a script running in scheduled tasks to force a computer restart.

You got **0** out of **9** correct.

Less

In ticket #2715, the finance office employee received what they thought was an email from a trusted vendor with instructions to download an application onto their workstation. This is a random phishing attack, as the attacker approached the shipping employee via email to improve his PC without submitting a request to do so. The attacker used an urgency tactic as a support technician from Microsoft to incite the need for the user to hurriedly download a malicious application. Tier 1 support notes indicate that the attacker modified the host file on the system with malicious entries. You should mitigate this type of attack by using email filtering, which will help mitigate the risk of personnel receiving future phishing emails.

In ticket #2723, the new admin assistant mentions receiving a call from someone who identified themselves as a member of the HR department in order to gain their trust and get them to open an attachment they were going to email to them. Using the phone for a phishing-type attack is vishing. It turns out that the HR person was actually an attacker who used an approach of authority to trick the employee. As Tier 1 support noted, a script ran every hour on the hour. You should mitigate this type of attack at the beginning of the incident by employing caller ID, which would

Related Content

pbq_practice_1.question.fex

Question 56 Correct

Which of the following can be consequences of a data breach? (Select the three best options.)

- [x] Reputation damage ✓ Correct
- [ ] Escalation
- [x] Fines ✓ Correct
- [x] Identity theft ✓ Correct

Explanation

Data breaches can reflect negatively on a business and its ability to protect sensitive consumer information. Breaches can make consumers less likely to use the business again, damaging the company's reputation.

Fines are money that a court of law or another authority has levied on a company or a person as a penalty for wrongdoing. Fines are a consequence of data breaches.

Identity theft is intentionally using someone else's identity to gain a financial advantage or benefit without the other person's knowledge. Identity theft can be a consequence caused by breaches of usernames, passwords, or personally identifiable information (PII).

Escalation is the process of moving a problem or concern to a higher level of authority or deeper expertise.

Related Content

resources\questions\sy0-701_5_4_011.question.xml

Question 57 Correct

During a recent security audit, a security specialist identified an attack that takes advantage of a vulnerability in an application, enabling an attacker to write data beyond the allocated space. What type of attack has likely occurred?

- (selected) Buffer overlfow ✓ Correct
- Cross-site scripting (XSS)
- Distributed denial-of-service (DDoS)
- Structured query language (SQL) injection

Explanation

A buffer overflow is an application attack where an application is vulnerable to an attacker writing data beyond the end of allocated space.

Structured query language (SQL) injection is an attack strategy to exploit applications that form SQL queries from user-provided input. While it is a common application attack, it does not involve writing data beyond allocated space.

XSS enables attackers to inject client-side scripts into web pages viewed by other users, which does not fit the scenario provided.

DDoS is an attack coming from multiple systems in an attempt to exhaust resources. However, it does not involve exploiting and overwriting the application's memory allocation.

Related Content

resources\questions\sy0-701_2_4_010.question.xml

Question 58 Correct

A help-desk technician assists a new employee with setting up a new password. When creating a password, what best practice incorporates using upper and lowercase letters, numbers, and symbols?

- Age
- Length
- Complexity ✓ Correct
- Reuse

Explanation

Password complexity enforces rules to make guessing a user's password more difficult, such as incorporating a combination of upper and lowercase letters, numbers, and symbols into the selected password.

Password age forces a user to select a new password after a set number of days.

Password reuse prevents the selection of a password that the computer user may have previously used.

Account policies can enforce credential management principles by stipulating requirements for user-based password creation. One of these requirements is password length, which enforces a minimum, and sometimes maximum, length for passwords.

Related Content

resources\questions\sy0-701_4_6_015.question.xml

Question 59 Correct

A proprietary software remains mission-critical ten years after its in-house creation. The software requires an exception to the rules as it cannot use the latest in-use operating system (OS) version. How can the IT department protect this mission-critical software and reduce its exposure factor? (Select the two best options.)

- [x] Compensating controls ✓ Correct
- [ ] Vulnerability feeds
- [ ] Patching
- [x] Network segmentation ✓ Correct

Explanation

Segmentation is a means of making the exploitation of a vulnerability across a network more difficult, as segmented areas keep attackers from moving laterally across the network.

It requires compensating controls when unable to remediate or eliminate the vulnerability directly. They provide additional steps to take to resolve the exposure.

The vulnerability feed is a synchronizable list of data and scripts to check for vulnerabilities, called plug-ins or network vulnerability tests (NVTs). It will not reduce the exposure factor.

While patching is usually the primary means of vulnerability resolution, it is impossible with this software.

Related Content

resources\questions\q_pt_sy0-701_4_3_008.question.xml

Question 60 Correct

The IT department of a local governmental agency is in the process of finalizing a contract with a third-party vendor to provide cloud services. The agency is highly concerned about data security and wants to ensure it can assess the vendor's security practices. The IT team decides to include a right-to-audit clause in the contract to ensure periodic audits of the vendor's security measures. Additionally, the agency wants an independent assessment of the vendor's security controls to ensure unbiased evaluation. Which of the following accurately concludes the primary purpose of including a right-to-audit clause and seeking independent assessments in the contract with the cloud service vendor?

- To grant the vendor the right to conduct audits on the company's internal systems
- To exempt the vendor from security compliance requirements
- To ensure the company can periodically assess the vendor's security practices ✓ Correct
- To provide the vendor with access to sensitive customer data

Explanation

The agency gains assurance from the right-to-audit clause, enabling them to verify the vendor's security posture and identify potential vulnerabilities or shortcomings in its security controls.

The agency obtains the ability to conduct audits on the vendor's systems and practices through a right-to-audit clause. It does not grant the vendor authority to audit the agency's internal systems.

Including a right-to-audit clause does not exempt the vendor from security compliance requirements. Instead, it ensures the company verifies the vendor's compliance through periodic audits.

The right-to-audit clause evaluates the vendor's security capabilities rather than providing them access to unnecessary data for the agreed-upon services.

Related Content

resources\questions\sy0-701_5_3_009.question.xml

Question 61 Correct

The newly appointed IT manager of a growing e-commerce company has initiated a security review to ensure compliance with industry standards. This process includes defining clear roles and responsibilities for data and system owners to optimize the organization's security posture. According to the IT manager's new plan, which of the following would be the primary responsibility of a system owner in the context of cybersecurity?

- (selected) Establishing the security controls for systems ✓ Correct
- Conducting network penetration tests
- Implementing a disaster recovery plan
- Prosecuting individuals who perpetrate cyberattacks

Explanation

System owners are primarily responsible for defining, implementing, and maintaining appropriate security controls for the systems under their authority.

Specialized cybersecurity professionals perform penetration tests rather than system owners. These tests involve simulating cyber attacks to identify and address security vulnerabilities.

Although system owners play a role in disaster recovery, this task is generally the responsibility of a disaster recovery team or a business continuity team. These teams design and implement strategies to ensure business operations can continue after a disaster.

Law enforcement agencies and legal professionals manage legal actions against cybercriminals, not system owners. System owners should focus on improving system security and mitigating potential threats.

Related Content

resources\questions\q_pt_sy0-701_5_1_007.question.xml

Question 62 Correct

A large multinational corporation is restructuring its IT division. The corporation defines roles, responsibilities, and levels of authority for different tasks across various teams. What type of tool is the corporation likely to use to document this information?

- Infrastructure as code
- IT service catalog
- Risk register
- Responsibility matrix ✓ Correct

Explanation

A responsibility matrix is a tool for clearly defining roles and responsibilities for tasks, decisions, and deliverables in a project.

Infrastructure as code manages and provisions IT infrastructure through machine-readable definition files. It does not define roles and responsibilities.

A risk register identifies and assesses potential risks in a project or organization. Although it might be part of a larger project plan, it does not define roles and responsibilities.

An IT service catalog is a list of IT services that an organization provides to its employees or customers. It does not outline roles and responsibilities for tasks or decisions in the IT division.

Related Content

resources\questions\sy0-701_3_1_005a.question.xml

Question 63 Correct

An IT admin has been testing a newly released software patch and discovered an exploitable vulnerability. The manager directs the IT admin to immediately report to Common Vulnerability Enumeration (CVE), utilizing the common vulnerability scoring system (CVSS) to base the score for the vulnerability. What could happen if there are delays in completing the report? (Select the two best options.)

- [x] Increase window of opportunity for attackers ✓ Correct
- [ ] The vulnerability will be patched
- [ ] Verification will resolve the vulnerability
- [x] Can lead to delays in remediation ✓ Correct

Explanation

Any possible delay in reporting a new vulnerability can translate into additional time in which an administration can identify remediation for the vulnerability.

The longer a vulnerability is accessible in the open wild, the more likely an attacker will be able to use the vulnerability in an attack on an organization.

Delaying reporting on a new vulnerability will not patch the vulnerability but can hinder the progress of a possible patch creation.

Verification occurs after remediation efforts, which confirms the successful completion of all steps without introducing any possible new vulnerabilities.

Related Content

resources\questions\q_pt_sy0-701_4_3_004.question.xml

Question 64 Correct

A system administrator prepared to implement full-disk encryption (FDE) on all company laptops to enhance data security. Each laptop contained various levels of sensitive information, and the administrator granted access based on employee roles. What is the MOST crucial factor the system administrator considered while implementing full-disk encryption to ensure data security and to maintain employee accessibility?

- Encrypt only the most sensitive data records.
- Use the highest possible encryption level.
- Use a common encryption key for all laptops.
- Assign encryption keys based on employee roles. ✓ Correct

Explanation

Assigning encryption keys based on employee roles ensures that employees can only access data relevant to their job, enhancing data security while maintaining accessibility.

While a high level of encryption might enhance data security, it could also negatively impact system performance. Additionally, the level of encryption is irrelevant if not combined with proper key management and access control mechanisms.

Encrypting only the most sensitive data records does not meet the FDE requirements. FDE involves encrypting the entire hard drive, not just selecting data records.

Using a common encryption key for all laptops potentially compromises them and does not account for differential access requirements based on employee roles.

Related Content

resources\questions\q_pt_sy0-701_1_4_006.question.xml

Question 65 Correct

When performing forensic investigation in public clouds, what document would contain the right-to-audit clause and give the investigator the authority to audit files on the network?

- Supply chain analysis
- Checksums
- Forensic reports
- Service Level Agreement (SLA) ✓ Correct

Explanation

An SLA is a formal agreement that lays out the detailed conditions for how the vendor will conduct the service. These could include terms and conditions for security access controls and risk evaluations, plus authentication criteria for proprietary and private data.

A digital forensics report summarizes the significant contents of digital data and the conclusions of the analysis.

Supply chain analysis evaluates the risks and vulnerabilities associated with the various entities (vendors) involved in a supply chain by examining the security practices, capabilities, and individual vendors' reliability within the supply chain network.

A checksum of two hashes can validate that the investigators did not tamper with the contents of a disk.

Related Content

resources\questions\q_pt_sy0-701_5_3_001.question.xml

Question 66 Correct

After encountering a cyber attack, an organization uses a monitoring solution that automatically restarts services after it has detected the system has crashed. What type of functional security control is the company implementing?

- (selected) Corrective ✓ Correct
- Managerial
- Compensating
- Technical

Explanation

Corrective control actively responds to an incident, fixes it, and prevents it from happening again. Antivirus software exemplifies a corrective control.

Rather than preventing an attack, a compensating control actively restores the functionality of systems via alternative methods, such as using a backup.

The implementation of technical controls occurs in operating systems, software, and security appliances such as access control lists (ACLs) or intrusion prevention systems (IPS).

Managerial security controls actively shape behavior through policies, procedures, and guidance. A fair use policy serves as an example of such a control.

Related Content

resources\questions\q_sy0-701_1_1_008.question.xml

Question 67 Correct

An attacker is attempting to gather information about a person by using text messages. Which of the following describes the attacker's phishing technique?

- SPIM
- Smishing ✓ Correct
- Vishing
- Spam

Explanation

Smishing is a phishing technique that uses simple message service (SMS) text communications as the attack vector. The text message may include a link to a fake website asking a user to log in.

Spam or unsolicited messages, like emails, sent in bulk to users for advertisements or to deliver malware.

SPIM is spam (or mass unsolicited messages) over instant messaging or Internet messaging services.

Vishing is a phishing attack conducted through a voice channel (telephone or Voice over Internet Protocol, for instance). Someone may attempt to represent a bank and ask the target to verify information over the phone.

Related Content

resources\questions\sy0-701_2_2_015.question.xml

Question 68 Correct

The security manager at a financial technology company seeks to enforce a control that enhances user behavior to mitigate cybersecurity risks. What type of control should an analyst recommend the security manager put in place?

- [x] The analyst should recommend the enforcement of a strict password policy. ✓ Correct
- [ ] The analyst should recommend a tool that assesses potential security risks.
- [ ] The analyst should recommend installing biometric security devices.
- [ ] The analyst should recommend the placement of security cameras around the premises.

Explanation

The enforcement of a strict password policy is an example of an operational control. People primarily implement operational controls and involve actions, such as adhering to security policies and procedures.

A tool that assesses potential security risks falls under managerial controls. These controls provide oversight of the information system and help evaluate and select other security controls.

The installation of biometric security devices falls under the category of technical controls. For example, hardware, software, or firmware represent technical controls within a system.

The placement of security cameras around the premises is a physical control. Physical controls are measures that deter and detect access to premises and hardware.

Related Content

resources\questions\q_sy0-701_1_1_002a.question.xml

Question 69 Correct

A network administrator for a technology company is introducing a new cybersecurity model to limit data breaches. They wish to enforce a strategy where every system or user inside or outside the network perimeter must prove their legitimacy before accessing resources. What principle would be MOST effective in implementing their new strategy?

- Policy-driven access control
- Role-based access control (RBAC)
- Adaptive identity
- Zero Trust ✓ Correct

Explanation

Zero Trust verifies the authenticity of every system or user trying to connect to its resources, serving as the best strategy in this scenario.

Adaptive identity involves systems dynamically adjusting user access rights based on behavior or context rather than requiring every system or user to prove their legitimacy.

Role-based access control (RBAC) does not necessitate the verification of every system or user, as is the central idea of zero trust.

Policy-driven access control does offer a layer of security by determining who to allow access to specific network resources. But it does not incorporate the verify-everything concept of Zero Trust.

Related Content

resources\questions\q_pt_sy0-701_1_2_005.question.xml

Question 70 Correct

After receiving a below-average rating, a board of directors implements holistic compliance monitoring changes. What are some characteristics of internal compliance monitoring? (Select the two best choices.)

- [ ] Works to provide service to shareholders, customers, clients, regulators, vendors, and business partners
- [x] Provides service to risk managers, executives, security analysts, and privacy officers ✓ Correct
- [ ] Provides high-level summaries of an organization's compliance performance and ensures adherence to regulatory requirements
- [x] Concentrates on operational details and supports the company's decision-making ✓ Correct

Explanation

Internal and external compliance reporting aim to assess and disclose an organization's compliance status but differ in scope, audience, and purpose. Internal compliance reporting primarily serves internal stakeholders, such as risk managers, executives, security analysts, and privacy officers.

Internal compliance reporting also focuses on operational details and supports internal decision-making.

External compliance reporting targets external stakeholders, such as shareholders, customers, clients, regulators, vendors, and business partners. Internal and external reporting forms promote accountability, transparency, and effective organizational compliance management.

External compliance reporting adheres to regulatory requirements and provides high-level summaries of an organization's compliance performance.

Related Content

resources\questions\sy0-701_5_4_004.question.xml

Question 71 ✕ Incorrect

A technician wants to implement automation within the team's workspace. How does complexity impact automation and orchestration?

- It can result in poorly documented code, leading to instability and increased costs. ✕ Incorrect
- It can quickly erode if they do not continue the needed patches and updates.
- It can impact multiple areas of the organization, causing widespread problems.
- Poorly planned strategies can make systems difficult to maintain. ✓ Correct

Explanation

While automation and orchestration provide numerous benefits, they can also present numerous challenges. A poorly planned or executed automation strategy can add complexity, making systems difficult to maintain.

Single points of failure can impact multiple areas of the organization, causing widespread problems since no redundancy of operations exists.

When organizations make haste decisions in technology, technical debt can result in poorly documented code or maintenance. Over time, technical debt can lead to system instability and increased costs.

Automation and orchestration require ongoing support to stay effective and secure. Automation and orchestration will quickly erode without support.

Related Content

resources\questions\sy0-701_4_7_008.question.xml

Question 72 Correct

An organization observes several computer systems in a secured area showing signs of damage, having various cables disconnected, or hardware component tampering. Which type of attack is likely responsible for these issues?

- (selected) Physical attacks ✓ Correct
- Insider threats
- Malware attacks
- Denial-of-service attacks

Explanation

Physical attacks involve direct, tangible harm to computer systems or related infrastructure. Physical attacks could involve manually tampering with hardware components, disconnecting cables, or gaining unauthorized access to secure physical locations.

An attacker usually carries out malware attacks remotely, introducing malicious software onto systems to perform unauthorized activities.

Insider threats might misuse their access to steal information or disrupt operations, but the physical damage observed is not typically associated with insider threats. In this case, unauthorized access occurred.

Attackers mostly perform denial-of-service attacks remotely and involve overloading systems with data or requests instead of causing physical damage to infrastructure.

Related Content

resources\questions\q_pt_sy0-701_2_4_014.question.xml

Question 73 Correct

A healthcare provider is digitalizing its patient data and needs a system that guarantees the preservation of its sensitive data in the event of a disaster while avoiding lock-in to a single technology vendor's platform. What is the MOST crucial practice the provider needs to implement?

- Adopting platform diversity for their digital infrastructure
- Incorporating additional power generators
- Implementing an Uninterruptible Power Supply (UPS)
- Maintaining regular data backups ✓ Correct

Explanation

Regular data backups provide a reliable way to restore data if the original becomes compromised, lost, or corrupted due to a disaster.

A UPS system ensures continuity of operations in the face of smaller-scale disruptions, like power outages, rather than handling large-scale data loss scenarios.

Platform diversity is a strategic decision about technology procurement and management rather than a specific data preservation measure.

Incorporating additional power generators maintains service availability during power disruptions. They do not preserve data integrity during a disaster or contribute to avoiding vendor lock-in.

Related Content

resources\questions\q_pt_sy0-701_3_4_006.question.xml

Question 74 Correct

A company's IT team has detected an anomaly in a cloud-based environment after a recent software update. There are suspicions that the update could contain malicious code, potentially leading to unauthorized access to sensitive data. Which of the following actions should the IT team take as a first step to address the threat posed by the potential malicious update?

- Migrate all data to a different cloud service provider immediately.
- Implement two-factor authentication for all user accounts.
- Isolate the affected systems and perform a rollback to the previous update. ✓ Correct
- Update firewall rules to block all incoming traffic.

Explanation

Isolating affected systems and performing a rollback to the previous update is the correct initial step. This action could prevent further compromise and enable the IT team to investigate the anomaly more thoroughly.

Updating firewall rules to block all incoming traffic does not address the issue of a potentially malicious update already deployed on the system. It would also prevent legitimate traffic, affecting business operations.

Implementing two-factor authentication for all user accounts is a good general security practice but would not address the immediate issue of a potentially malicious update.

Migrating all data to a different cloud service provider is an extreme and time-consuming measure that does not address the immediate threat and could introduce new complications and potential vulnerabilities.

Related Content

resources\questions\sy0-701_2_3_013.question.xml

Question 75

Incorrect

Instructions

Based on the scenario, use the **dropdown selectors** to implement an access control model and accurately define the Access Methods, Security Roles, and Authentication Methods for several different user groups.

Which model is best suited to assign access based on job roles?	Select
Which principle is foundational in securing sensitive patient data?	Select
What authentication method should be prioritized for securing highly sensitive patient information?	Select

Doctor Access | Nurse Access | External Auditor Access

You got **0** out of **12** correct.

Less

Role-Based Access Control (RBAC) assigns users roles based on their job duties, making it apt for distinct roles in a hospital setting. Discretionary Access Control (DAC) can lead to inconsistent permissions, Mandatory Access Control (MAC) is overly rigid with its label-based access, and Attribute-Based Access Control (ABAC) is too intricate for the outlined scenario.

Implicit Deny emphasizes denying all unless expressly permitted. Open Access and Guest Access grant broader access than desired, while Full Control risks potential data misuse.

Biometric Authentication is superior due to its unique identification attributes. Password Authentication is susceptible to breaches, Knowledge-Based Authentication is easy to decipher, and Location-Based Authentication needs to be more lenient.

Given their need for comprehensive patient data, doctors should use VPN for secure remote access, fall under the Database Editor role, and employ MFA for enhanced security. Other methods like Public Web Service and Direct Database Links can compromise data security.

Related Content

pbq_practice_2.question.fex

Question 76 Correct

An organization is implementing an intrusion prevention system (IPS) as part of its efforts to secure its enterprise infrastructure. The IT manager is considering the failure modes of the IPS and is deciding between a fail-open and a fail-closed configuration. What are the implications of each configuration on network traffic in the event of a system failure?

- Both fail-open and fail-closed will block all traffic.
- Both fail-open and fail-closed will allow all traffic.
- Fail-open will block all traffic, while fail-closed will allow all traffic.
- Fail-open will allow all traffic, while fail-closed will block all traffic. ✓ Correct

Explanation

An IPS can either allow all traffic through without disruption but with a risk of malware (fail-open) or block all traffic without malware but with a risk of disruption (fail-closed).

In the event of a system failure, a fail-open configuration allows all traffic, while a fail-closed configuration blocks all traffic.

Even if the system fails, a fail-open configuration allows all traffic to pass through, ensuring that there is no disruption to the flow of data and information.

If the system fails, a fail-closed configuration blocks all traffic from passing through, ensuring that no malware or other harmful content can enter the network.

Related Content

resources\questions\sy0-701_3_2_010.question.xml

Question 77 Correct

In a large corporate office, employees use various devices such as laptops, smartphones, and tablets that support both Bluetooth and Wi-Fi connectivity. The office implements strict security measures to protect sensitive data and ensure compliance with industry regulations. However, the IT team noticed some security concerns. What security risks is the IT team primarily concerned about regarding the use of Bluetooth and Wi-Fi in the corporate office?

- (selected) Unauthorized access and data interception ✓ Correct
- Physical damage to devices
- Lack of connectivity
- Incompatibility with devices

Explanation

The IT team has primary concerns about the risk of unauthorized access and data interception through Bluetooth and Wi-Fi connections in the corporate office, which could lead to data breaches and compromise sensitive information.

While physical damage to devices is a valid concern, it is not the primary security risk related to Bluetooth and Wi-Fi usage in the scenario.

While compatibility issues can be a concern, such as delaying workflow in the office, they are not the main security risks highlighted in the scenario.

While internet connectivity is essential for communications and access to company resources in the cloud, it is not the primary security concern for using Bluetooth and Wi-Fi in the corporate office.

Related Content

resources\questions\q_pt_sy0-701_4_1_004.question.xml

Question 78 Correct

A crypto exchange company is revising its security policies and is concentrating on implementing effective operational security controls. Which of the following should the company's security manager recommend executing?

- [x] The enforcement of a strict password policy ✓ Correct
- [ ] A tool that assesses potential security risks
- [ ] The placement of security cameras around the premises
- [ ] Enforce biometric controls on computing devices

Explanation

The enforcement of a strict password policy is an example of an operational control. People primarily implement operational controls and involve actions, such as adhering to security policies and procedures.

A tool that assesses potential security risks falls under managerial controls. These controls provide oversight of the information system and help evaluate and select other security controls.

The installation of biometric security devices falls under the category of technical controls. For example, hardware, software, or firmware represent technical controls within a system.

The placement of security cameras around the premises is a physical control. Physical controls are measures that deter and detect access to premises and hardware.

Related Content

resources\questions\q_sy0-701_1_1_002b.question.xml

Question 79 Correct

The intelligence community needs to secure highly classified data stored on local servers. The servers need protection from tampering and completely removed from any networked systems to prevent digital threats. Which of the following is the BEST solution for securing these assets?

- Protected distribution system (PDS)
- Screened subnet
- Physical isolation ✓ Correct
- Vault

Explanation

Physical isolation is the best solution for the scenario described. It involves completely disconnecting the server from all networks, which secures the stored data by preventing digital intrusions.

A vault can provide significant physical protection for hardware but does not inherently protect against digital threats. It does not provide network isolation required in this scenario.

A protected distribution system (PDS) is a system of information distribution that offers high levels of security for the physical transport of data but does not inherently guarantee network isolation.

A screened subnet is a network security architecture that creates a buffer zone between an organization's internal and external networks. However, it does not completely isolate the network as an air gap does.

Related Content

resources\questions\sy0-701_3_1_014.question.xml

Question 80 Correct

A major corporation seeks to strengthen its security measures following a recent breach. The actor breached information regarding those not associated with the organization and exploited a weakness in the organization's physical defenses to gain unauthorized access to sensitive data. What type of security threat did the corporation face?

- Internal physical threat
- Unassociated digital threat
- External physical threat ✓ Correct
- Internal digital threat

Explanation

External physical threat pertains to threats originating outside the organization and targeting its physical infrastructure. The actor in the scenario, unassociated with the organization and exploiting a weakness in the physical defenses, aligns with this description.

An internal physical threat refers to threats within the organization targeting its physical assets. The actor does not affiliate with the organization, ruling out this option.

Unassociated digital threat involves an actor outside the organization exploiting weaknesses in the organization's digital security measures. The scenario does not suggest any exploitation of digital security measures.

Internal digital threat couldn't apply because it involved organizational threats that target digital security measures.

Related Content

resources\questions\q_pt_sy0-701_5_5_003.question.xml

Question 81 Correct

A global technology firm detected unauthorized access to its proprietary designs for an upcoming product. The intruders remained undetected for an extended period and extracted a large volume of confidential data without disrupting the company's operations. This stealthy, long-term breach aimed at acquiring secret information aligns BEST with which type of threat motivation?

- (selected) Espionage ✓ Correct
- Financial
- Chaotic
- Revenge

Explanation

Espionage, characterized by stealthy, long-term breaches, aims at acquiring secret information, often for strategic advantage. The intruders' focus on the proprietary designs and their ability to remain undetected aligns with this motivation.

Revenge motivations typically involve a disgruntled individual seeking retaliation. This scenario does not provide evidence of a personal grievance or individual retaliation.

While financial motivation often involves monetary gain through methods such as blackmail, extortion, or fraud, the primary goal in this scenario is acquiring proprietary information, not explicit financial gain.

Chaotic motivations aim to disrupt for its own sake, often as an act of vandalism or to sow chaos. However, this scenario's targeted, stealthy, and organized nature of the attacks suggests a more sophisticated motivation.

Related Content

resources\questions\q_sy0-701_2_1_010.question.xml

Question 82 Correct

A cyber technician pulls logs on the new Apple iMacs to ensure the company's employees adhere to the policy. What log can provide the technician with the computer's attempted logins or denial when an employee attempts to access a file?

- (selected) Operating system-specific security logs ✓ Correct
- Endpoint logs
- Firewall logs
- Application logs

Explanation

Operating system (OS)-specific security logs record audit events on the operating system itself, such as events on attempted logins and access to file denials.

Firewall logs are an audit tool that records a date/time stamp, the interface the rule triggers, whether the rule matches incoming/ingress or outgoing/egress traffic, and whether the packet accepts or drops.

An application rather than the OS manages an application log file and may use Event Viewer or syslog to write event data using a standard format.

An endpoint log will likely refer to events monitored by security software running on the host rather than the OS.

Related Content

resources\questions\q_pt_sy0-701_4_9_002.question.xml

Question 83 Correct

A system admin implement a process that assigns all users a username and password combination that allows them to interact with specific areas of the network. Which mitigation technique should the system admin implement?

- Access control lists
- Monitoring
- Configuration enforcement
- Access control ✓ Correct

Explanation

Access control refers to regulating and managing the permissions granted to individuals, software, systems, and networks to access resources or information.

Access control lists (ACLs) enforce access control policies in computer systems and networks.

Configuration enforcement ensures that systems and devices within a network have the same configuration, allowing for easier identification of compromised systems and ensuring a standard baseline. Configuration enforcement does not control permissions.

Monitoring plays a vital role in the hardening process and can provide valuable data for compliance and auditing purposes, but it is not part of assigning permissions.

Related Content

resources\questions\sy0-701_2_5_006.question.xml

Question 84 Correct

An organization implemented a bring your own device (BYOD) policy for employees to use their mobile devices for work-related tasks. The organization's IT department identified concerns about the security risks associated with BYOD. They determined that employees' mobile devices must meet the security requirements to protect sensitive company data. Considering the scenario, which of the following measures is the MOST effective way to enhance the security of employees' mobile devices under the BYOD policy?

- (selected) Using mobile device management (MDM) solutions to centrally control employees' mobile devices ✓ Correct
- Providing employees with company-owned mobile devices
- Enforcing complex passwords for all employee mobile devices
- Restricting all access to company resources from mobile devices

Explanation

Mobile device management (MDM) solutions enable the organization to control employees' mobile devices centrally, enforce security policies, perform remote data wipes in case of loss or theft, and ensure devices remain updated and compliant with security standards.

Although company-owned devices can offer better control, they may not always be feasible under a bring your own device (BYOD) policy and can incur significant costs for the organization.

Completely restricting access to company resources may hamper productivity and negate the advantages of the BYOD policy.

While strong passwords are crucial, relying solely on them does not encompass all security concerns related to BYOD. An MDM solution presents a more comprehensive approach.

Related Content

resources\questions\sy0-701_4_1_011.question.xml

Question 85 Correct

A tech company is in the process of decommissioning a fleet of old servers. It wants to ensure that sensitive data stored on these servers is fully eliminated and are not accesible in the event of unauthorized attempts. What primary process should the company implement before disposing or repurposing these servers?

- Selling the servers immediately
- Sanitizing the servers ✓ Correct
- Deleting all the files on the servers
- Moving the servers to a secure storage location

Explanation

Sanitizing the servers uses specialized techniques, such as data wiping, degaussing, or encryption, to ensure the data becomes irretrievable.

Deleting all files on the servers is ineffective because deleting files from a magnetic-type hard disk does not fully erase them.

Moving the servers to a secure location and keeping them untouched does not address the need to remove sensitive data from the servers. If someone accesses the servers without authorization, it would increase the data breach risk.

Selling the servers immediately without considering the stored data is risky as it could lead to unauthorized access to sensitive data, legal liabilities, and reputational damage.

Related Content

resources\questions\q_pt_sy0-701_4_2_003.question.xml

Question 86 Correct

A company plans to upgrade its wireless network infrastructure to improve connectivity and security. The IT team wants to ensure that the new network design provides adequate coverage, minimizes interference, and meets security standards. To achieve this, they conduct a site survey and create a heat map of the area. What is the primary purpose of conducting a site survey and creating a heat map for the company's wireless network upgrade?

- To identify potential security threats and vulnerabilities in the existing network
- To map out the physical layout of the building and identify potential obstacles that could affect wireless signal strength
- To assess wireless signal coverage, identify dead zones, and optimize access point placement for the new network design ✓ Correct
- To evaluate the performance and bandwidth usage of the current wireless network

Explanation

Conducting a site survey and creating a heat map allows the IT team to assess the wireless network's coverage, identify dead zones, and optimize the placement of access points for the new network design. This process helps ensure that the new wireless infrastructure provides adequate coverage and minimizes potential connectivity issues.

The primary focus of the site survey and heat map is not on identifying security threats but on optimizing wireless signal coverage.

While mapping the physical layout is part of the process, the main purpose is to optimize coverage.

The survey is not primarily about evaluating performance and bandwidth usage but about coverage and placement optimization.

Related Content

resources\questions\sy0-701_4_1_001a.question.xml

Question 87 Correct

Given the need to prioritize cost-effective solutions for enhancing the company's cybersecurity posture, a global corporation's chief security officer (CSO) considers implementing technical controls over physical controls. Which of the following options is a technical control?

- Implementing a risk identification tool
- Setting up a network intrusion detection system ✓ Correct
- Conducting employee cybersecurity training
- Installing a building access control system

Explanation

Setting up a network intrusion detection system is an example of a technical control. It involves hardware and software systems specifically designed to monitor and control the network's security, thus serving as a cost-effective solution for improving the cybersecurity posture.

A risk identification tool falls under the category of managerial controls. These controls oversee the information system and aid in selecting and implementing other security controls.

Employee cybersecurity training is an operational control. Operational controls are primarily human-centric and focus on procedures and responsibilities to maintain the security of the organization.

Installing a building access control system is a physical control. Physical controls manage access to premises and hardware, often incurring higher implementation and maintenance costs compared to technical controls.

Related Content

resources\questions\q_sy0-701_1_1_001a.question.xml

Question 88 ✕ Incorrect

A tech department must develop asset protection standards for the organization after several laptop computers went missing from a storage bank. How does classification assist in ensuring the organization is effectively managing and protecting its resources while maintaining accountability? (Select the best three options.)

- [ ] It enables effective prioritization for maintenance. ✓ Correct
- [x] It enables consistent and repeatable activity. ✓ Correct
- [x] It involves organizing assets based on their value and sensitivity. ✓ Correct
- [x] It establishes a clear chain of accountability. ✕ Incorrect

Explanation

Asset classification is essential to a well-structured asset management process, ensuring that organizations effectively manage and protect their resources while maintaining accountability. Asset classification involves organizing assets based on their value, sensitivity, or criticality to the organization.

Asset classification enables the consistent and repeatable application of required security controls.

Asset classification enables effective prioritization for maintenance and updates and appropriate budget allocation.

Not considered asset classification, asset ownership involves designating specific individuals or teams within the organization as responsible for particular assets to establish a clear chain of accountability for asset security, maintenance, and ongoing management.

Related Content

resources\questions\sy0-701_4_2_010.question.xml

Question 89 Correct

A company transmits data across a network, ensuring the non-repudiation security principle. What is the key benefit this provides to both the sender and the recipient of the data?

- Both parties can adapt their identity dynamically.
- Both parties have control over authentication, authorization, and accounting.
- Neither party can deny the authenticity of the data. ✓ Correct
- Both parties should not trust anything inside or outside the network.

Explanation

Non-repudiation is a security principle that ensures data originated from a verified sender and reached the intended recipient. This process means neither party can deny the authenticity of the data.

Adaptive identity is a part of advanced access control models but does not directly provide the certainty of data origin and receipt that non-repudiation does.

Not trusting anything inside or outside the network is a zero-trust policy. It does not provide non-repudiation.

While authentication, authorization, and accounting (AAA) is a key security framework used to control user access and track user activity in an organization's network, it does not inherently provide non-repudiation.

Related Content

1.1.2 Cybersecurity Framework

resources\questions\q_sy0-701_1_2_001b.question.xml

Question 90 Correct

A cyber intern implements new endpoint configurations after advisement of a data exfiltration that includes top-secret information. What configuration consideration can ensure that systems and devices within an organization's network adhere to mandatory security configurations?

- (selected) Configuration enforcement ✓ Correct
- Monitoring
- Access control
- Access control lists

Explanation

Configuration enforcement describes methods to ensure that systems and devices within an organization's network adhere to mandatory security configurations.

Organizations can use access control lists (ACLs) in computer systems and networks to enforce access control policies. An ACL is a list of rules or entries that specify a user or a group's access to specific resources or ability to perform certain actions.

Access control refers to regulating and managing the permissions granted to individuals, software, systems, and networks to access resources or information.

Monitoring plays a vital role in endpoint hardening, helping to enforce and maintain the security measures put in place during the hardening process.

Related Content

10.1.1 Endpoint Hardening

resources\questions\q_pt_sy0-701_2_5_002.question.xml

Copyright © CompTIA, Inc. All rights reserved.